

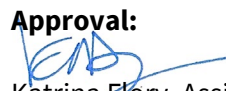


DAS Policy

Contingency Planning

No:
2100-16

Effective:
March 5, 2024

Approval:

Katrina Flory, Assistant Director/State CIO

I. Purpose

The purpose of this policy is to provide **Contingency Planning** (CP) requirements to minimize the disruption to critical business functions in the event of an information technology (IT) system disruption, compromise, or failure, while maintaining the security safeguards originally planned and implemented for systems.

To ensure this occurs, this policy establishes requirements that address Contingency Planning controls that align with the National Institute of Standards and Technology (NIST) Special Publication (SP) 800-53, "Security and Privacy Controls for Federal Information Systems and Organizations," (CP family of controls).

The first occurrence of the word in the policy body outside of a title or heading is in bold, italic type, and is hyperlinked to the definition in Section IV.

II. Scope

The scope of this policy includes any **Department of Administrative Services (DAS)-Managed Information System** or service, as well as services provided by **External Service Providers** on behalf of DAS. This policy also applies to DAS business, **Data**, and system/**Service Owners**.

III. Policy

For the purposes of this policy, the term "information system" is inclusive of information systems or information services operated by DAS or by an External Service Provider on behalf of DAS. Each information system shall adhere to the following requirements:

A. **Contingency Plan (CP-2)**: Each DAS information system/Service Owner shall develop and maintain a contingency plan, which:

1. Identifies essential missions and business functions, critical assets, and associated contingency requirements.
2. Addresses maintaining essential missions and business functions despite an information system disruption, compromise, or failure.
3. Provides recovery objectives (i.e., **Recovery Time Objective (RTO)**, **Recovery Point Objective (RPO)**), restoration priorities, and metrics.
4. Addresses eventual, full information system restoration in accordance with defined recovery objectives without deterioration of the security safeguards originally planned and implemented.
5. Defines contingency roles, responsibilities, and contact information for assigned individuals.
6. Is coordinated with the:
 - a) Disaster recovery plans for the actual or dependent information system or service;
 - b) DAS Business Continuity Plan; and
 - c) DAS Security Incident Response Plan.
7. Is reviewed and approved by the business owner, DAS Office of Information Technology leadership, and the DAS Office of Business Continuity.
8. Is distributed to the DAS Office of Business Continuity and the Office of Information Security and Privacy (OISP).
9. Is reviewed and updated no less than annually, or as needed, to address changes to the organization, information system, or operating environment, or when problems are encountered during contingency plan execution, or testing.
10. Is protected from unauthorized disclosure or modification.

B. **Contingency Training (CP-3)**: DAS system owners and external information system providers shall provide contingency training to their respective information system users consistent with assigned roles and responsibilities:

1. Prior to assuming a contingency role or responsibility.
2. When required by information system changes.
3. Annually thereafter.

C. **Contingency Plan Testing (CP-4)**: DAS system/Service Owners and External Service Providers shall:

1. Test the contingency plan for the information system or service no less than annually to determine the effectiveness of the plan and their ability to execute the plan.

2. Test the contingency plan in coordination with:
 - a) Actual or dependent information system or service disaster recovery plans for the information system or service.
 - b) The DAS Security Incident Response Plan.
 3. Review the contingency plan test results.
 4. Initiate corrective actions, if needed.
- D. **Alternate Storage Site (CP-6):** DAS or external information system providers shall establish an alternate storage site and necessary agreements, which:
1. Permit the storage and retrieval of information system backup information.
 2. Provide information security safeguards equivalent to that of the primary site.
 3. Is separated from the primary storage site to reduce its susceptibility to the same threats.
- E. **Alternate Processing Site (CP-7):** DAS or external information system providers shall establish an alternate processing site and necessary agreements, which:
1. Permit the transfer and resumption of information system operations, in accordance with the contingency plan, when the primary processing capabilities are unavailable.
 2. Ensure that equipment and supplies required to transfer and resume operations are available at the alternate processing site or contracts are in place to support delivery to the site within the contingency plan defined time period for transfer/resumption.
 3. Ensure that the alternate processing site provides information security safeguards equivalent to those of the primary site.
 4. Is separated from the primary processing site to reduce its susceptibility to the same threats.
 5. Provide agreed upon priority of service provisions, commensurate with system or service criticality, at alternate processing sites with multiple customers.
- F. **Telecommunications Services (CP-8):** DAS or external information system providers shall establish alternate telecommunications services, including necessary agreements, to permit the resumption of voice and Data communications for essential missions and business functions within 24 hours when the primary telecommunications capabilities are unavailable at either the primary or alternate processing or storage sites. Primary and alternate telecommunications services agreements shall contain priority-of-service provisions commensurate with system criticality.
- G. **Information System Backup (CP-9):** DAS **Data Owners**, system/Service Owners and External Service Providers shall:

1. Conduct a risk assessment, as required in DAS Policy 2100-08, "Risk Assessment," to determine the necessity and frequency of backups for user-level information (to include transaction Data), system-level information, and security-related documentation. The defined scope and frequency of backups shall be documented in the system or service contingency plan.
 2. Protect the **Confidentiality, Integrity, and Availability** of backup information at storage locations.
 3. Test backup information quarterly to verify **Media** reliability and information Integrity.
 4. If users have approval to engage in teleworking in accordance with DAS Policy 200-14, "Teleworking," procedures shall be in place to mitigate and address the added risks associated with teleworking and remote access to resources. Users shall be required to adhere to state and agency policies, standards, and contracts while accessing resources via a teleworking environment.
- H. **Information System Recovery and Reconstitution (CP-10)**: DAS system/Service Owners and External Service Providers shall provide the capability for the recovery and reconstitution of the information system or service to a known state after a disruption, compromise, or failure.

Transaction-based information systems (i.e., Database management or transaction processing systems) shall implement transaction recovery.

IV. Definitions

- A. Availability. Ensuring timely and reliable access to and use of information.¹
- B. Confidentiality. Preserving authorized restrictions on information access and disclosure, including means for protecting personal privacy and proprietary information.²
- C. Contingency Planning. Management policy and procedures designed to maintain or restore business operations, including computer operations, possibly at an alternate location, in the event of emergencies, system failures, or disasters.³

¹ "NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations," U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

² *Ibid.*

³ Swanson, Marianne, Pauline Bowen, Amy Wohl Phillips, Dean Gallup, David Lynes. "NIST Special Publication 800-34 Rev. 1, Contingency Planning Guide for Federal Information Systems," U.S. Department of Commerce National Institute of Standards and Technology, May 2010 <<https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-34r1.pdf>>.

- D. DAS-Managed Information Systems. Information systems that reside in facilities or infrastructure managed by DAS OIT personnel. Primary responsibility for managing these systems may be assigned to DAS OIT personnel or other outside entities.
- E. Data. Coded representation of quantities, objects, and actions. The word, “Data,” is often used interchangeably with the word, “information,” in common usage and in this policy.
- F. Data Owner. The Data Owner is responsible for the identification and classification of information, in consultation with legal counsel, and shall address the assignment of Data classification labels, Data compilation, Data classification coordination, Data classification compliance and Data access. The role of a Data Owner and his/her associated responsibilities are addressed in detail within Ohio Administrative Policy IT-13, “Data Classification.”
- G. External Service Provider. An entity outside State of Ohio government that provides external information system or service capabilities to DAS by contract.
- H. Integrity. Guarding against improper information modification or destruction, and includes ensuring information non-repudiation and authenticity.⁴
- I. Media. Any device that is capable of storing information. Media is not required to be capable of processing information.
This definition includes, but is not limited to, the following:
 - 1. External/removable hard drives
 - 2. Magnetic tapes
 - 3. Portable Devices
 - 4. Optical Media such as compact disks (CDs), digital video disks (DVDs), etc.
 - 5. Thumb drives (USB keys)
- J. Recovery Point Objective (RPO). This describes the latest available point in time from which Data can be restored to be acceptable to the Data Owner. The Recovery Point Objective is established based on tolerance for loss of Data and helps determine backup frequency requirements.
- K. Recovery Time Objective (RTO). The overall length of time an information system’s components can be in the recovery phase before negatively impacting the organization’s mission or mission/business processes.⁵
- L. Service Owner. A Service Owner is responsible for the delivery (design, performance, integration), continual improvement and management of assigned IT services.

⁴ “NIST Special Publication 800-53 Revision 4, Security and Privacy Controls for Federal Information Systems and Organizations,” U.S. Department of Commerce National Institute of Standards and Technology, April, 2013 <<https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf>>.

⁵ Swanson, Marianne, Pauline Bowen, Amy Wohl Phillips, Dean Gallup, David Lynes. “NIST Special Publication 800-34 Rev. 1, Contingency Planning Guide for Federal Information Systems,” U.S. Department of Commerce National Institute of Standards and Technology, May 2010 <<https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-34r1.pdf>>.

V. Authority

ORC 125.18

VI. Resources

Document Name	Location
NIST Special Publication 800-53, Security and Privacy Controls for Federal Information Systems and Organizations	https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.800-53r4.pdf
Ohio IT Standard ITS-SEC-02 Security Controls Framework	https://das.ohio.gov/technology-and-strategy/policies
Ohio Administrative Policy IT-13 Data Classification	https://das.ohio.gov/technology-and-strategy/policies
DAS Policy 2100-08 Risk Assessment	https://das.ohio.gov/technology-and-strategy/policies

VII. Inquiries

Direct inquiries about this policy to:

Office of Information Security & Privacy
Office of Information Technology
Ohio Department of Administrative Services
30 East Broad Street, 39th Floor
Columbus, Ohio 43215

614-644-6860 | state.isp@das.ohio.gov

DAS Policies may be found online at
<https://das.ohio.gov/technology-and-strategy/policies>

VIII. Revision History

This policy shall be reviewed no less than every two years and updated as needed.

Date	Description of Change
2/8/2018	Original Policy.

Date	Description of Change
12/21/2018	Revised the policy to clarify information system backup requirements.
06/10/2020	Updated the policy template. Added requirements related to DAS Policy 200-14, "Teleworking."
06/22/2021	Conducted routine maintenance review of citations and references.
03/05/2024	Updated the policy template. Added a revision history review frequency statement.